Informática Forense y Respuesta ante Incidentes

Tema 9. Respuesta a incidentes

Índice

Esquema

Ideas clave

9.1. Introducción y objetivos

9.2. Planificación de la respuesta a incidentes

9.3. Gestión de un incidente de seguridad

9.4. Corporate Forensics

9.5. Referencias bibliográficas

A fondo

Normas aplicables a DFIR

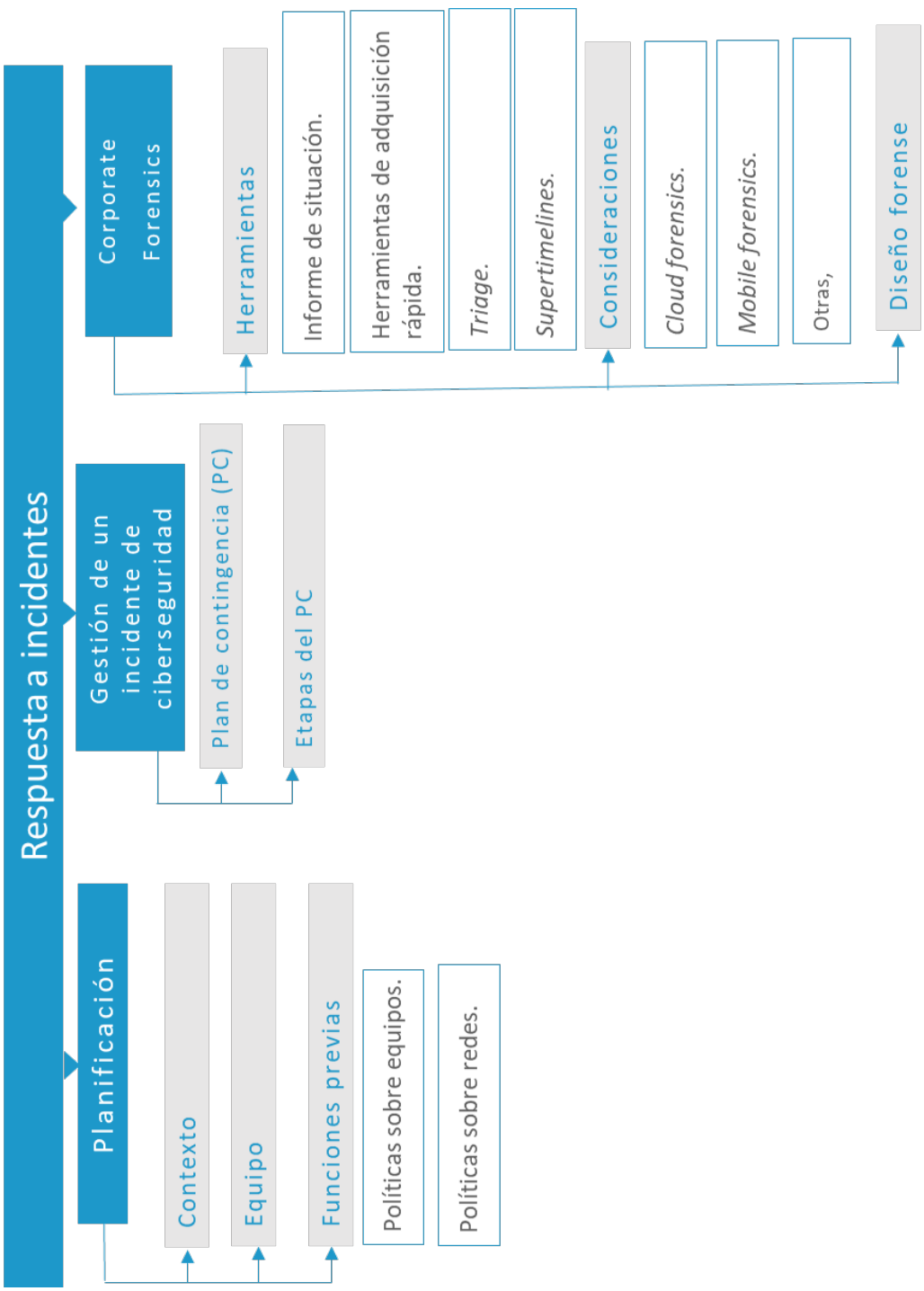
Respuesta a incidentes: políticas de seguridad para la PYME

Guide to Integrating Forensic Techniques into Incident Response

A Digital Forensic investigative model for business organisations

Test

Esquema



© Universidad Internacional de La Rioja (UNIR)

9.1. Introducción y objetivos

En el presente tema estudiaremos desde dos enfoques:

- **Corporativo y de gestión:** donde veremos, desde un punto de vista organizativo, cómo crear y gestionar un equipo de respuesta a incidentes.
- **Tecnológico:** donde analizaremos la respuesta a incidentes desde el punto de vista técnico y operativo.

Por último, hablaremos del análisis forense en el marco de una respuesta ante incidentes, y concluiremos con una serie de recomendaciones para diseñar sistemas resilientes donde el análisis forense pueda ser desarrollado con rapidez y eficacia.

Al finalizar este tema el alumno deberá:

- Entender la importancia y los procedimientos de la recuperación ante desastres.
- Diseñar mecanismos de DFIR a nivel de gestión corporativa.
- Gestionar un incidente adecuadamente a nivel tecnológico.
- Diseñar arquitecturas con huella forense amplia.

© Universidad Internacional de La Rioja (UNIR)

9.2. Planificación de la respuesta a incidentes

Introducción a la respuesta a incidentes

Vamos a cerrar el círculo sobre DFIR. Vamos a continuación a ver la parte de Incident Response (IR) para terminar de nuevo con forense corporativo (corporate Forensics.

La respuesta a incidentes trata de la concepción y ejecución de un procedimiento estructurado para manejar un incidente desde el momento que se detecta hasta su resolución.

Algunas de las labores a desarrollar dentro de la respuesta a incidente son:

- Detección temprana.
- Confirmación: determinar lo que ha ocurrido.
- Análisis de alcance.
- Contención temprana.
- Coordinación en la respuesta.
- Reducción del impacto en el negocio.
- Coordinación de la información tanto interna como externa (imagen corporativa).
- Restauración a la operación normal.
- Educación y concienciación.
- Asistencia en demandas y otras labores judiciales.

© Universidad Internacional de La Rioja (UNIR)

Ideas clave

En el actual contexto de ciberataques cada vez más complejos, la labor de respuesta a incidentes implica un mayor conocimiento y control, así como equipos más preparados. Vamos a ver a continuación cómo se prepara una respuesta a incidentes desde un entorno corporativo.

Factores a tener en cuenta a la hora de planificar una respuesta a incidentes

Existe una serie de factores clave de los que va a depender el éxito de una recuperación y por tanto han de ser tenidos en cuenta y analizados en el momento de desarrollar el plan de contingencia. Estos factores son:

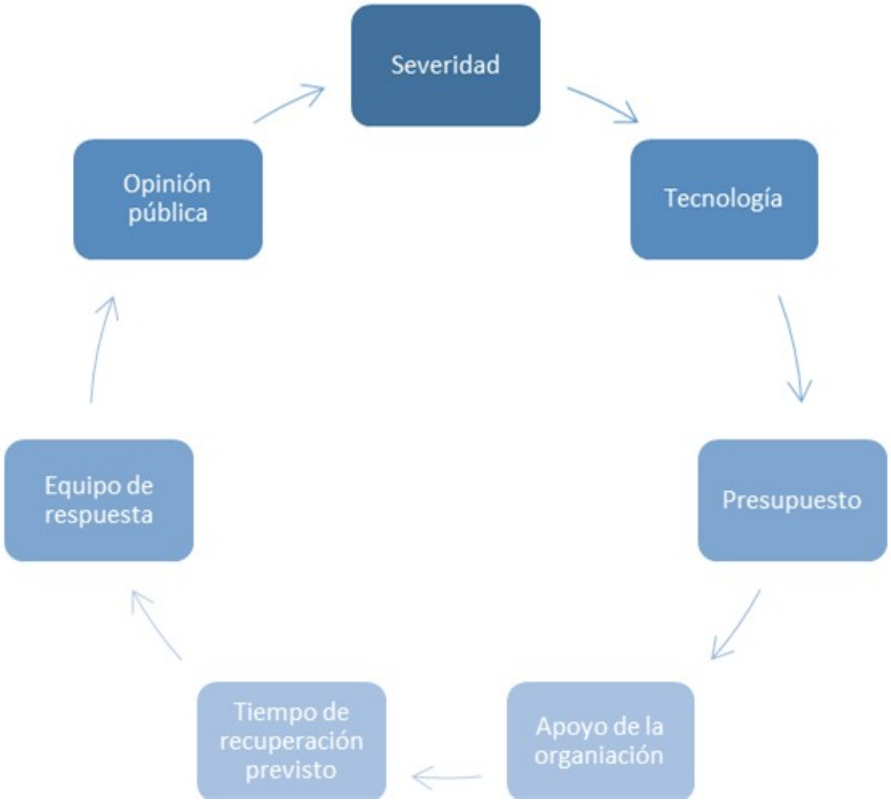


Figura 1. Factores a tener en cuenta en DFIR. Fuente: elaboración propia.

- **Severidad del incidente:** la severidad del incidente es algo relativo y muy relacionado con el propio negocio en sí. Un mismo incidente puede ser más severo en un tipo de negocios que en otros (ejemplo, una exfiltración de datos de clientes

© Universidad Internacional de La Rioja (UNIR)

puede tener relativamente poca importancia en un negocio que vende material de oficina mientras que es crítico en una clínica). Las empresas deberían tener planes de contingencia preparados para aquellos incidentes más severos para su *core* de negocio.

- **Tecnología**: no solo nos referimos a la tecnología de seguridad que se dispone, siendo claro, a mejor tecnología de seguridad, mayor capacidad de respuesta, sino también a la propia tecnología vinculada con los procesos de negocio de tal modo que un mayor control de los procesos de negocio nos permitirá desplegar medidas con mayor rapidez.

- **Presupuesto:** es evidente que un mayor presupuesto de seguridad es una buena garantía de éxito, pero hay que tener en cuenta la curva de inversión en seguridad, en la que, al principio, pequeñas inversiones en seguridad retornan un gran beneficio, pero, cuando la inversión en seguridad ya es alta, los beneficios de inversión de la misma cantidad cada vez son menores. Además, se ha de tener en cuenta el coste de la protección frente a los activos que se protegen.

- **Apoyo de la organización:** las medidas a tomar van a implicar a toda la organización tanto en su funcionamiento actual como, quizá, futuro por lo que toda la organización debe estar comprometida.

- **Tiempo de recuperación previsto:** teniendo en cuenta que hay negocios en los que las interrupciones son más críticas que en otros, también es necesario encontrar un punto de equilibrio entre una buena «limpieza» y una recuperación rápida. Este suele ser un punto de confrontación entre el equipo de negocio y el de IT; y es necesario el apoyo de la dirección en uno u otro sentido dependiendo de la estrategia corporativa.

- **Equipo de respuesta:** en este sentido hay tres puntos importantes que son el tamaño del equipo, el «poder» del equipo (en cuanto a compromiso por parte de la dirección) y la capacidad de este. La capacidad no solo depende de una buena formación y experiencia, sino, también, de un adiestramiento constante.

© Universidad Internacional de La Rioja (UNIR)

- **Opinión pública:** en tiempos de crisis la discreción es importante. Muchas veces, dependiendo de las intenciones del atacante (extorsión, interrupción de servicio, robo de datos, etc.), el revelar la menor cantidad de información posible es una buena política, pero, además, está la opinión pública y los interesados y su derecho a ser informados. En este caso hay que manejar adecuadamente la información y de manera prudente. La información que se suministre ha de ser adecuadamente medida y ha de ser de utilidad para quien la recibe. Muchas veces existe la tendencia de «sobreinformar» para dar sensación de transparencia y de que se está respondiendo al ataque puntualmente.

Equipo de respuesta a incidentes

Según lo anterior, una parte importante a tener en cuenta a la hora de responder a un incidente es quién va a encargarse de dicha labor.

Esto pasa por la creación de un equipo multidisciplinar de DFIR. Dicho equipo habitualmente no tiene una «dedicación exclusiva» durante el resto del tiempo de no-crisis, sino que es *personal senior* de varios departamentos (en especial, de IT). En grandes empresas este equipo sí tiene un núcleo fijo y dedicado que suele ser personal especializado en Forensics.

Pero el proceso de respuesta a incidentes no es algo exclusivo del equipo de DFIR ni tampoco del departamento de IT. Implica a gran parte de la organización, gestionada por el equipo de DFIR. La respuesta a incidentes es una labor que se extenderá más allá de los departamentos de la empresa, cambiando la estructura corporativa por un tiempo de modo que el equipo de DFIR tomará el control y coordinará al resto de las áreas implicadas. Vemos a continuación cuáles serían estas áreas:

© Universidad Internacional de La Rioja (UNIR)

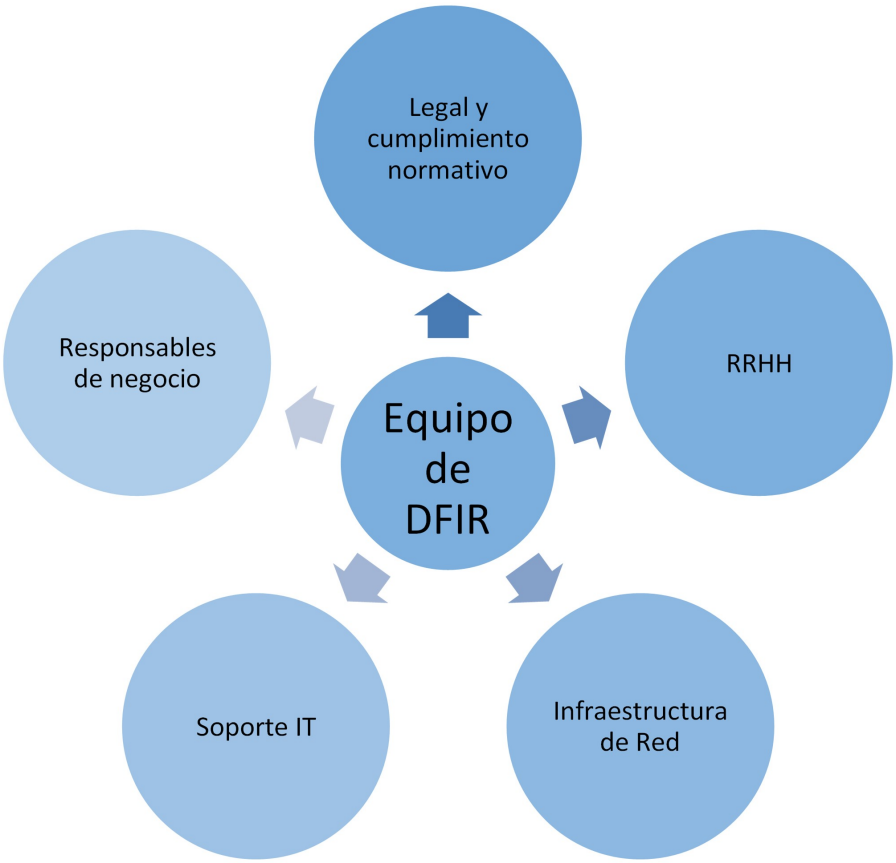


Figura 2. Miembros del equipo de DFIR. Fuente: elaboración propia.

Este equipo de DFIR tendrá unos **miembros clave** que serán:

- **Responsable de equipo:** que, habitualmente, suele ser el CIO o CISO por sus capacidades de poder acceder y recopilar diferentes tipos de información corporativa de manera rápida.
- **Responsable de recuperación:** suele ser un perfil con alto conocimiento dentro del equipo de IT, ya que tendrá que coordinar aspectos muy técnicos; y se requiere una persona con solvencia tecnológica.
- **Equipo de investigación:** encargados del análisis *forens.* Si no hay equipo de forense en la empresa, este suele estar formado por técnicos *senior* con experiencia en análisis de logs y análisis de *malware.* Este equipo deberá hacer, además,

© Universidad Internacional de La Rioja (UNIR)

labores de *triage* para acotar la información a manejar. Este departamento deberá interactuar con legal para establecer los límites de la investigación.

Cabe destacar en la parte de legal y cumplimiento normativo no solo con el cumplimiento de la legislación vigente, sino, también, con la parte de normativa como estándares de calidad, estándares de pago, etc.

Labores previas

Vamos a ver cómo preparar la infraestructura tecnológica de cara a un incidente y con objetivo de poder dar la mejor respuesta posible.

Aunque las tecnologías son cambiantes, el modo de extracción de datos e investigación permanece válido a lo largo de los años. Podemos, por tanto, analizar una serie de políticas que, una vez implantadas, nos ayudarán a mejorar la respuesta ante un incidente.

Dividiremos dichas políticas en dos:

- De equipos.
- De red.

Políticas sobre equipos informáticos

Los dispositivos informáticos van a presentar la mayor parte de las evidencias con las que vamos a trabajar. Es por ello tan importante una correcta configuración de estos.

Una aproximación hacia el modo de configurar los dispositivos es el de prestar mayor atención a aquellos dispositivos más importantes. Si bien esta aproximación es correcta de cara a la defensa, no lo es en cuanto a la recolección de evidencias, ya que la experiencia dice que la mayoría de las acciones se ejecutan desde equipos no críticos y solo cuando se tienen privilegios suficientes se escala hacia equipos críticos; de modo que la actividad quedará registrada en dicho equipo como una

© Universidad Internacional de La Rioja (UNIR)

actividad normal de un usuario autorizado.

Para poder establecer políticas efectivas de protección, lo primero que tenemos que determinar es exactamente con qué recursos contamos, para luego poder fortalecerlos.

- **Gestión de activos:** la gestión de activos es fundamental, ya que la única manera de proteger un recurso es saber que existe y, a la vez, todo recurso no catalogado es una posible brecha de seguridad. De este modo el primer paso es realizar un catálogo exhaustivo de cada equipo de la organización. De cada uno se debería conocer toda la información necesaria para su correcta gestión y localización. Esta labor se debería realizar periódicamente dentro de una organización, bien sea mediante auditorías presenciales o a través de formularios de encuesta, alimentando una base de datos y elaborando diagramas de red que nos permitan de manera visual localizar cada equipo. Es importante realizar un inventario de dispositivos y software, no solo autorizados, sino, también, no autorizados para saber dónde pueden existir vulnerabilidades, así como realizar un correcto control de versiones del *software* de los dispositivos. Existen también herramientas de autodescubrimiento que permiten chequear la red en busca de nuevos dispositivos.

- **Herramientas:** definimos como herramientas todos aquellos recursos que nos ayudarán en el caso de un posible incidente, tanto para realizar las labores de investigación como de mitigación. En este sentido podemos destacar:

  - Logs y registros de eventos, accesos, etc.
  - Antivirus y sistemas de prevención de intrusiones.
  - Herramientas de e-discovery.

- **Pasos adicionales para mejorar la seguridad:** existe una serie de recomendaciones útiles para mejorar la seguridad como gestión de parches, 2FA (autenticación de doble factor), control de acceso con privilegios, despliegue de

© Universidad Internacional de La Rioja (UNIR)

firewalls y antivirus, listas blancas y negras para aplicaciones, actualización de información y seguimiento de recomendaciones de entidades de seguridad (DISA, NSA, entre otros), etc.

Políticas de red

Del mismo modo que se deben proteger los equipos de trabajo, los dispositivos de red y en especial su topología es muy importante para definir correctamente el ámbito de actuación En este sentido vamos a ver una serie de ideas clave.

- **Segmentación de red y control de acceso:** la segmentación de la red siempre es una buena práctica para delimitar los riesgos en topologías grandes. Además, nos permite configurar anillos de seguridad. La segmentación se puede realizar por departamentos, por roles de seguridad, por manejo de información, por acceso a recursos, etc. En este sentido, para acceder de unas subredes a otras, podemos recurrir a filtrado de tráfico, autenticación fuerte, etc.

- **Documentación:** las redes suelen tener topologías complejas y, por tanto, es muy importante tener actualizada la documentación sobre las mismas, gráficos y esquemas, etc. Que, llegado el caso, nos permitan poder hacernos una idea rápida de la cobertura del incidente. Existen múltiples herramientas en el mercado que nos permiten dibujar gráficos de red analizando el rango de direcciones de manera automática, o a través de llamada a agentes de gestión. La información de red debe encontrarse centralizada, con acceso sencillo y visual y a través de una herramienta que permita una rápida reconfiguración para que de ese modo se facilite la labor de actualización.

- **Herramientas** del mismo modo que en los equipos de trabajo, a nivel de red existen múltiples recursos para ayudarnos a securizar nuestras arquitecturas. Las más típicas son:

  - Firewalls.

  - IDS.

© Universidad Internacional de La Rioja (UNIR)

- Sistemas de captura completa de sesión.
- Analizadores de tráfico.
- Proxys.
- Etc.

Anillos de seguridad

Un mecanismo típico de contingencia es el establecimiento de anillos de seguridad que nos permitan realizar **labores de contención rápidas.**

Con los anillos de seguridad, se agrupan los recursos relacionados entre sí con similar perfil de seguridad de modo que, si es necesario realizar contenciones, pueda delimitar claramente el riesgo limitando el acceso a los diferentes anillos y perimetrando de esta manera nuestros recursos.

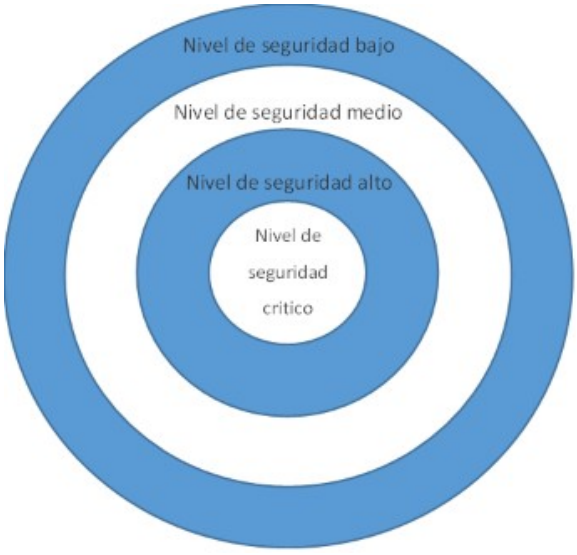


Figura 3. Anillos de seguridad. Fuente: elaboración propia.

© Universidad Internacional de La Rioja (UNIR)

9.3. Gestión de un incidente de seguridad

Una vez detalladas las acciones previas que pueden considerarse a la hora de mitigar un incidente de seguridad, nos encontramos en el punto en el que dicho incidente ya se ha producido, y tenemos que desarrollar acciones de contingencia.

Dichas acciones han de estar previstas *a priori* mediante una estrategia de actuación previamente preparada y acordada con toda la organización. Dicha estrategia se plasma en el plan de contingencia.

Plan de contingencia

Un plan de contingencia es el elemento fundamental de trabajo a la hora de comenzar las actividades de respuesta a un incidente. Notar que siempre merece la pena pararse a diseñar una respuesta adecuada.

El plan de contingencia habitualmente se organiza en dos grandes tareas, a saber:

- Defensa ante el inminente ataque con acciones técnicas como toma de posición, contención y erradicación.
- Refuerzo de la seguridad desde un punto de vista más estratégico.

Para realizar el plan de contingencia nos basaremos en una matriz de respuesta estado-acción:

© Universidad Internacional de La Rioja (UNIR)

	Prevenir	Detectar	Responder
Intrusión inicial			
Explotación de vulnerabilidad			
Escalado de privilegios			
Reconocimiento interno			
Movimiento lateral			
Mantenimiento de presencia			
Brecha completada			

Tabla 1. Matriz de respuesta estado-acción. Fuente: Luttgens et al. 2014.

En esta matriz determinaremos las posibles acciones a realizar dependiendo del estado de la amenaza y en los tres vectores de defensa que podemos ejecutar que son la prevención del ataque, la detección de este y la respuesta.

Una buena técnica de comienzo suele ser realizar un *brainstorming* sobre la misma para rellenar todas aquellas casillas que podamos.

Etapas de un plan de contingencia

Un plan de contingencia ha de tener en cuenta **seis fases,** a saber:

- **Preparación:** en la tarea de preparación se creará el equipo de trabajo, y se intentará determinar el tiempo con el que se cuenta, que se acordará entre las unidades de negocio y el equipo tecnológico en base a las necesidades del negocio y la experiencia previa estimación de tiempos de respuesta. Para determinar el tiempo, se pueden tomar tres posturas:

- **Acción inmediata:** este tipo de acción se ejecutará cuando la prioridad es detener al atacante y el ataque. Tiene el inconveniente de que, inmediatamente, se alerta al atacante.

- **Acción retardada:** en aquellos casos en los que se requiere conocer en detalle el

© Universidad Internacional de La Rioja (UNIR)

ataque o identificar al atacante —y es esto más importante que detener el ataque en sí— (por ejemplo, un caso de robo de información reservada), se retrasará la contingencia para poder finalizar la investigación. En muchos casos serán las fuerzas de la ley las que indiquen que se ha de actuar de esta manera.

- **Acción combinada:** es una aproximación intermedia en la que solo algunos aspectos son contenidos y el resto se retrasan para facilitar la investigación.

- **Desarrollar e implementar las acciones de toma de posición:** se entienden por acciones de toma de posición aquellas que se producen cuando el incidente ya está produciéndose. Son de dos tipos: **gestión de alertas** y **medidas de monitorización**, refuerzos de la seguridad como primera actuación sobre las vulnerabilidades más críticas y preparación de los sistemas para medidas masivas posteriores (como cambio de contraseñas, direcciones IP, usuarios, etc.).

- **Desarrollar e implementar las acciones de contención:** este tipo de acciones suele ser muy limitadas en el tiempo y, de gran impacto o agresividad, como desconectar máquinas o sistemas de ficheros de la red, apagado de dispositivos y máquinas virtuales, cierre de puertos. Las medidas de contención se deben tomar en el momento justo, esto es, una vez que el incidente se encuentra bien caracterizado, pero lo suficientemente pronto para que el ataque no haya progresado en exceso. Se deben acordar, además, con las unidades de negocio; y, en ocasiones, provocarán reacción del atacante.

- **Desarrollar el plan de erradicación:** el plan de erradicación consiste en eliminar los accesos indebidos del atacante o el control a determinados recursos y, por último, erradicación del sector de ataque. Estas medidas deben estar perfectamente coordinadas, definidas y documentadas; y se ejecutarán cuando la investigación esté próxima a terminar para no interferir con ella. Además, deben ser rápidas y quirúrgicas para que el atacante tenga el tiempo mínimo para reaccionar. Suelen implicar bien la ejecución de una serie detallada de pasos para limpiar los equipos o bien mediante el borrado y reconfiguración total de estos. Posteriormente, se debe

© Universidad Internacional de La Rioja (UNIR)

seguir monitorizando y confirmando que la erradicación ha sido satisfactoria.

- **Mejora tras la recuperación:** una vez que se ha recuperado el sistema, no nos hemos de conformar con volver a la situación anterior, sino que, además, se lo debería mejorar para que no vuelva a suceder. De las labores anteriores, surgirá una serie de recomendaciones que deberían ser implantadas a la mayor brevedad.

- **Documentación de lo acontecido** con el fin de que sirva como referencia en otras ocasiones, como archivo y que se puedan extraer lecciones aprendidas a futuro.

© Universidad Internacional de La Rioja (UNIR)

9.4. Corporate Forensics

El análisis forense en la respuesta ante incidentes

Hasta ahora nos hemos centrado en la parte de respuesta a incidentes, pero hay que tener en cuenta que de manera paralela se debe ir realizando el análisis forense correspondiente.

En este sentido nos encontramos con una contraposición de intereses:

- Por un lado, la recuperación del incidente debe ser lo más **rápida** posible para crear el **mínimo impacto.**
- Por otro lado, es necesario **conservar todas las evidencias** inalteradas hasta el momento en que estas puedan ser adquiridas para su posterior análisis.

En este punto muchos autores creen que el proceso de cuatro pasos del NIST debe ser contemplado para tener en cuenta el análisis forense corporativo. De hecho, el propio Dennis en 2006 generó una guía para integrar técnicas forenses dentro de la respuesta a incidentes donde marca tres factores a tener en cuenta en dicho proceso:

- El coste asociado al esfuerzo a desarrollar en la adquisición.
- El coste asociado al incremento en el tiempo de respuesta.
- El riesgo a asumir según la sensibilidad de los datos.

En este contexto nace en modelos como el de Forrester & Irwin en 2007 en los que se define una serie de pasos intermedios y, luego, la restauración del servicio se hace de manera paralela a la investigación tal, y como se puede ver en el gráfico inferior.

© Universidad Internacional de La Rioja (UNIR)



Figura 4. Modelo de Forrester & Irwin (2009) Fuente: elaboración propia.

A nivel corporativo lo que se suele realizar de manera habitual es una aproximación orientada a la **gestión de riesgos** con los siguientes pasos:

- Primero, se identifican los **activos** de la compañía.
- Se definen las **amenazas** asociadas a ellos.
- Con ello ya podemos valorar el riesgo de cada uno de los activos.

© Universidad Internacional de La Rioja (UNIR)

- A la hora de recuperación de los diferentes activos se valorará su riesgo y conforme a eso se realizará un análisis forense a mayor o menor nivel dentro de lo que se denomina un análisis forense por capas.

Análisis forense por capas

Un análisis forense por capas consiste en realizarlo en diferentes niveles de profundidad dependiendo de la importancia del recurso. De este modo, trabajaremos habitualmente con tres capas o *tiers:*

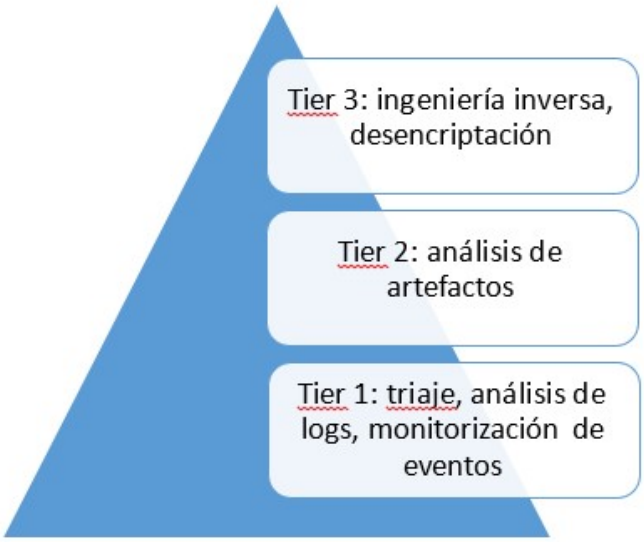


Figura 5. Modelo de análisis por capas Fuente: elaboración propia.

Escenario típico de trabajo: análisis de un APT

Un APT o amenaza avanzada persistente

Las APTs con ataques muy específicos en los que lo que se busca es hacer el mayor daño posible o penetrar al mayor nivel dentro de una infraestructura. Se van desplegando de manera silenciosa y van afectando a más y más máquinas siendo por tanto más difícil de eliminar luego.

© Universidad Internacional de La Rioja (UNIR)

Un caso reciente de dichos ataques es el de SolarWinds, una empresa de seguridad que ha afectado a un gran número de las principales empresas norteamericanas y a la propia Administración Gubernamental. En este caso un análisis forense es altamente necesario, pues hay que conocer hasta dónde ha penetrado dicho ataque para, así, poder limpiar todos sus rastros.

Herramientas forenses corporativas

Existen una serie de herramientas, recursos o procedimientos ampliamente utilizados en Corporate Forensics como son:

El informe de situación

En respuesta a incidentes es muy importante el orden y, para ello, se debe preparar un informe de situación. Este informe recopilará todos los datos relevantes de la investigación hasta el momento. Esta información será:

- **Lista de evidencias:** con fecha y hora de recolección y asegurando la cadena de custodia.
- **Lista de sistemas afectados:** señalando cuando fue identificado.
- **Lista de archivos de interés:** no solo *malware,* sino cualquier tipo de archivo que hayamos utilizado en la investigación.
- **Lista de datos accedidos y robados:** indicando fecha de la posible exposición.
- **Lista de actividad del atacante:** si hemos encontrado acciones realizadas por el atacante como *logeos,* ejecución de *malware,* etc. debemos documentarlo y datarlo.
- **Lista de IOCs de red:** con direcciones ip y nomtrs de dominio.
- **Lista de IOCs de hos**t: con los datos necesarios para su caracterización.
- **Lista de cuentas comprometidas:** tanto locales como de dominio.

© Universidad Internacional de La Rioja (UNIR)

- **Lista de tareas en curso y pendientes:** tanto del equipo propio como de equipos auxiliares.

Notar que un indicador de compromiso o IOC es un término forense que se refiere a la evidencia o dispositivo que apunta a una brecha de seguridad. Los IOC se recogen tras un incidente de seguridad o bien simplemente para detectar vulnerabilidades. Con ellos lo que se pretende es, en vez de analizar la totalidad de los recursos, intentar comenzar por aquellos que muestran IOC. No hay que confundirlos con los indicadores de ataque, pues estos últimos aparecen cuando ya es demasiado tarde.

Ejemplos de IOC son:

- Actividad anormal en usuarios con privilegios.
- Peticiones DNS extrañas.
- Tráfico web ilógico.
- *Logs* anormales.
- Cambios no habituales en el registro o en archivos de sistema.
- Cambios en perfiles móviles.
- Incremento en la lectura en bases de datos.
- Incoherencias geográficas.
- Etc.

El *triage*

Se utiliza para acelerar el proceso de análisis y es conocido como DFT o digital Forensics triage.

© Universidad Internacional de La Rioja (UNIR)

Del mismo modo que en el término médico, lo que se realiza es un análisis rápido buscando determinadas características que nos lleven a priorizar un determinado recurso (archivo, equipo, etc.) para un análisis posterior más pormenorizado. Esta labor necesita, habitualmente, del criterio de un experto, pero existen herramientas que ayudan en el proceso de adquisición rápida para el posterior examen (no hemos de olvidar que en la informática forense no nos podemos poner a analizar directamente, sino que hemos de adquirir las evidencias previamente).

En este caso la herramienta devolverá un archivo de evidencia digital que permitirá luego ser analizado. Las herramientas de *triage* suelen ser específicas para los diferentes sistemas operativos, ya que buscan en los artefactos típicos mediante una serie de reglas. Otras herramientas más combinan inteligencia artificial con técnicas estadísticas.

Herramientas de adquisición rápida

Existen soluciones completas para la adquisición que permiten, además, realizar varias en simultáneo para ahorrar tiempo; como, por ejemplo, dispositivos USB que se parametrizan para ser directamente ejecutados sobre una máquina, y realizan adquisiciones forenses de manera automática.

Existen otras soluciones más complejas que permiten conectarse a la unidad en cuestión mediante un cable que se suministra y extraer diferentes tipos de información a elección del usuario.

Todas estas herramientas facilitan, por un lado, que la adquisición pueda ser realizada por personal con unos conocimientos mínimos y algo de entrenamiento; y, por otro lado, que dicha adquisición se realice con la mayor rapidez dentro del contexto dado de respuesta a un incidente de seguridad.

Super Timelines

Un problema típico con el que nos encontramos es el de analizar una gran cantidad

© Universidad Internacional de La Rioja (UNIR)

de información temporal de manera simultánea, lo que permite ver la relación causa efecto entre unos hechos y otros acaecidos en diferentes equipos. El seguir líneas de tiempo en diferentes equipos es complejo y tedioso, pero hay sistemas que unifican dichas líneas de tiempo para ofrecer una visión única en una sola pantalla.

Estos sistemas de análisis de eventos trabajan con las denominadas superlíneas de tiempo que son diversos modos de agregación de la información temporal. El trabajar con *supertimelines* proporcionará mayor rapidez en el análisis y una herramienta de alta utilidad para el reporte de la información de manera visual y enriquecida.

Consideraciones sobre forense corporativo

En el caso de trabajar en Corporate Forensics, hemos de tener en cuenta una serie de consideraciones frente al análisis forense clásico:

Cloud Forensics

En el caso de compañías que tienen sus sistemas alojados en *cloud,* hay dos elementos fundamentales a tener en cuenta.

- Por un lado, la ubicación de las evidencias: no solo donde se encuentra el datacenter físicamente, ya que esto puede tener ciertas consideraciones legales, sino, también, si estamos hablando de una nube privada, pública o híbrida, ya que nuestro nivel de acceso para realizar las adquisiciones va a ser diferente, y vamos a tener que contar en mayor o menor medida con los administradores.

- Por otro lado, el paradigma de *cloud* que estemos utilizando, que va a hacer que podamos acceder a unas u otras evidencias en función del servicio prestado. Así, en SaaS trabajaremos con los *logs* de la aplicación y de la máquina virtual, en IaaS con snapshots, archivos, *logs* del hipervisor, etc. y en PaaS con *logs* de accesos a través e API, excepciones del SO, *warnings* de antivirus).

© Universidad Internacional de La Rioja (UNIR)

Mobile Forensics

El otro gran reto de las empresas en la actualidad es la movilidad.

En este caso estamos hablando de terminales en diferentes ubicaciones y con diferentes arquitecturas, más aún si la empresa trabaja bajo la política Bring Your Own device, en cuyo caso la adquisición de los terminales tiene implicaciones legales a resolver de manera previa, ya que se utilizan para uso personal e, incluso, son de propiedad individual y no de la empresa.

Además, la adquisición de terminales móviles es más compleja que los PCs, ya que casi siempre nos vamos a encontrar dispositivos encriptados de difícil acceso si no se tiene el patrón de desbloqueo. En este sentido lo que se recomienda es prevenir y utilizar soluciones de MDM (Mobile Device Management) en los terminales corporativos que faciliten, posteriormente, la labor de acceso a la información y, además, creen entornos aislados para uso personal y profesional, lo que evita problemas legales.

Otras consideraciones generales

Como últimas consideraciones, tenemos que implicar a la dirección en el proceso forense ya que se debe trabajar con sumo cuidado y siguiendo un plan de intervención estricto, pero, aunque sea el departamento forense el que lleve el mando de la operación.

El conocimiento muchas veces reside en los otros departamentos con lo que se debe escuchar e involucrar a toda la organización, y en este sentido solo si existen unos procedimientos de actuación claros, bien definidos y conocidos por todos, la organización completa funcionará en la misma dirección.

Por último, insistir en que todo lo que vayamos a hacer puede acabar en un

© Universidad Internacional de La Rioja (UNIR)

procedimiento judicial, por lo que siempre se ha de actuar dentro de la legalidad.

Forensic by design

El trabajo forense debe comenzar mucho antes de la respuesta a incidentes. El diseño de la propia arquitectura de seguridad ha de tener en cuenta que, en un momento dado, se deberán realizar análisis forenses y facilitar dicha labor. Esto es lo que se denomina «forensic by design».

En este sentido es muy importante **tener un inventario completo de equipos y dispositivos,** documentando claramente usuarios, roles, responsabilidades y políticas de uso.

Para tener toda la información actualizada, se debe tener en cuenta todo esto; no solo en el propio diseño, sino, también, en el mantenimiento de los sistemas, actualizando las auditorías, centralizando los *logs* y, si es posible, subiéndolos a la nube, realizando *backups* de manera regular, coleccionando una base de datos de *hashes* comunes en la organización que ayude en el proceso de *triage* y teniendo una política correcta de almacenamiento de información y también de borrado e historificado de datos para intentar tener menos información viva para analizar.

Se ha de tener en cuenta también que, en el momento en que se produzca un incidente de seguridad, todas las manos son pocas; y, aunque la empresa tenga un departamento forense *in house,* va a ser necesario contar con otros recursos de IT. En este sentido, la existencia de documentación de procedimientos y herramientas forenses puede facilitar mucho el trabajo.

© Universidad Internacional de La Rioja (UNIR)

9.5. Referencias bibliográficas

Luttgens et al (2014). *Incident Response & Computer Forensics.* Third Edition. McGraw Hill.

Murdoch D. (2014). *Blue Team Handbook: Incident Response Edition: A condensed field guide for the Cyber Security Incident Responder.* Second Edition. CreateSpace Independent Publishing Platform.

Chicano, E. (2014). *Gestión de incidentes de seguridad informática.* IC Editorial.

Gomez, A. (2011). *Gestión de incidentes de seguridad informática.* Starbook Editorial.

Tehan, R. (2008). *Data Security Breaches: Context and Incident Summaries.* Ed. Nova Science.

Organización Internacional de Normalización (2016). *Directrices para la identificación, recopilación, adquisición y preservación de la evidencia digital* (ISO/IEC 278037). https://www.une.org/encuentra-tu-norma/busca-tu-norma/norma?c=N0057481.

© Universidad Internacional de La Rioja (UNIR)

Normas aplicables a DFIR

Organización Internacional de Normalización (2016). Normas ISO 27041, 27042 y 27043. https://www.une.org/encuentra-tu-norma/busca-tu-norma/.

Además de la 27037, hay otra serie de normas que aplican a DFIR, y se recomienda su lectura:

- **ISO 27041:** es una guía para garantizar la idoneidad y adecuación de los métodos de investigación. Proporciona una serie de buenas prácticas y procedimientos para la investigación y el análisis de las evidencias, desde la selección de herramientas hasta la verificación y validación de todos procesos, detallando procedimientos estándar de operación en diferentes casuísticas.

- **ISO 27042:** es una guía con directrices para el análisis y la interpretación de las evidencias digitales; de modo que dicho análisis sea válido, reproducible y repetible. Define un marco común para diferentes tipos de análisis teniendo en cuenta la complejidad y los diferentes caminos que puede aplicar el analista.

- **ISO 27043:** desarrolla principios de investigación para la recopilación de evidencias digitales. Parte desde la preparación previa al incidente, y se extiende hasta el cierre de esta ofreciendo una serie de procesos aplicables a varios tipos diferentes de investigación (accesos no autorizados, corrupción de datos, caídas de sistemas…).

© Universidad Internacional de La Rioja (UNIR)

Respuesta a incidentes: políticas de seguridad para la PYME

Instituto Nacional de Ciberseguridad. INCIBE. *Políticas de seguridad para la pyme: respuesta a incidentes*. https://www.incibe.es/sites/default/files/contenidos/politicas/documentos/respuesta-incidentes.pdf.

En este documento se detallan las políticas de seguridad que se deben tener en cuenta no solo en las grandes empresas, sino, también, en la pequeña y mediana de cara a la recuperación frente posibles incidentes de seguridad.

© Universidad Internacional de La Rioja (UNIR)

Guide to Integrating Forensic Techniques into Incident Response

Kent et Al. (2006). National Institute of Standards and Technology. Guide to Integrating Forensic Techniques into Incident. 800.86. https://csrc.nist.gov/publications/detail/sp/800-86/final.

En esta guía el NIST desglosa la problemática de integrar el análisis forense en un contexto de respuesta a incidentes.

© Universidad Internacional de La Rioja (UNIR)

A Digital Forensic investigative model for business organisations

Forrester, J. & Irwing, B. (2007). Noroff University College. https://www.researchgate.net/publication/228783555_A_Digital_Forensic_investigative_model_for_business_organisations.

En este *paper* se define un nuevo modelo para Digital Forensics, y se analiza su utilidad en el proceso de DFIR.

© Universidad Internacional de La Rioja (UNIR)

Test

1. La labor de priorizar el análisis de unas evidencias frente a otras y establecer la profundidad de análisis de estas se denomina:

A. Digital Forensics.

B. Análisis de Logs.

C. IOC.

D. Triage.

2. ¿Qué es la respuesta a incidentes?

A. La concepción y ejecución de un procedimiento no estructurado para manejar un incidente desde el momento en que se detecta hasta su resolución.

B. La concepción de un procedimiento estructurado para manejar un incidente desde el momento que se detecta hasta su resolución.

C. La concepción y ejecución de un procedimiento estructurado para manejar un incidente desde el momento que se detecta hasta su resolución.

D. La concepción de un procedimiento no estructurado para manejar un incidente desde el momento que se detecta hasta su resolución.

3. Bajo la idea *«forensic by design»:*

A. Se deben realizar aplicaciones forenses con un adecuado interfaz de usuario.

B. Debemos tener en cuenta cuando diseñamos nuestra arquitectura que en el futuro necesitaremos realizar, en algún momento, un análisis forense.

C. Se diseñarán procedimientos forenses estándar para la recuperación de cualquier tipo de sistemas.

D. Se buscarán perfiles técnicos con la doble visión de diseño web y análisis forense.

© Universidad Internacional de La Rioja (UNIR)

4. Un informe de situación forense en el contexto de respuesta a incidentes debe contener:

A Lista de cuentas comprometidas.

B. Cuando se trata de un equipo que no se puede apagar.

C. Lista de evidencias con fecha y hora de recolección.

D. Todas las anteriores son correctas.

5. ¿Qué importancia tiene la gestión de activos en la respuesta a incidentes?

A. Es importante disminuir el número de activos controlados para, de ese modo, realizar una recuperación más rápida.

B. La gestión de activos debe realizarse de manera descentralizada y por departamentos; disminuyendo así la carga sobre el equipo de IT.

C. No es necesario gestionar los *endpoints,* solo la infraestructura central.

D. La única manera de saber qué partes de nuestros sistemas se han visto comprometidas es tener un correcto inventario de activos.

6. ¿Cuáles de los siguientes departamentos no es necesario que forme parte del equipo de respuesta a incidentes?

A. RRHH.

B. Legal.

C. Calidad.

D. IT.

© Universidad Internacional de La Rioja (UNIR)

7. ¿Qué hemos de tener en cuenta al realizar análisis forenses de arquitecturas *cloud?*

A. La ubicación física del cloud.

B. El tipo de *cloud* (Iaas, Paas, SaaS…).

C. La calidad del *datacenter.*

D. La A y la B son ciertas.

8. ¿Cómo se debe reaccionar en los momentos iniciales de un incidente?

A. Siempre lo antes posible, ya que así se minimiza el riesgo.

B. Dependerá siempre del objetivo de dicha acción.

C. La acción siempre debe ser retardada para evitar la reacción del atacante.

D. Dependerá solo de la gravedad del ataque.

9. La segmentación de red y los anillos de seguridad:

A. Son mecanismos de contención de ataques.

B. Son mecanismos de gestión de incidentes de seguridad.

C. Son dos mecanismos de prevención para contener posibles ataques que se puedan producir.

D. La A y la C son ciertas.

10. Un plan de contingencia debe contener:

A. Solo las tareas de defensa ante el inminente ataque.

B. Tareas de defensa ante el ataque y tareas de refuerzo de la seguridad desde un punto de vista estratégico.

C. Tareas de defensa ante el ataque, tareas de refuerzo de la seguridad y un presupuesto detallado.

D. Tareas de defensa ante el ataque, tareas de refuerzo de la seguridad, un presupuesto detallado y un plan de seguimiento a, al menos, tres años.

© Universidad Internacional de La Rioja (UNIR)